信息安全测评与风险评估

7.3.1 物联网架构认知

授课教师：张玉



目录

CONTENTS

01 案例导入

02 学习目标

03 什么是物联网？

04 物联网的发展历程

案例导入——半个美国的断网：Mirai与10万台摄像头



2016年10月21日，美国东海岸的Twitter、Netflix、PayPal集体打不开——为它们提供域名解析的Dyn公司遭到大规模流量攻击，半个美国的互联网瘫痪。发动攻击的，是一支由约10万台摄像头、路由器、打印机组成的“僵尸军团”，代号Mirai。它们靠扫描出厂默认口令入侵，把主人从没配置过的“哑终端”变成了攻击弹药。

问题：为什么偏偏是这些最不起眼的小设备，撬动了半个国家的网络？

学习目标

通过本课学习，你将能够：

- **理解**物联网的基本概念和核心特征
- **掌握**物联网三层架构（感知层、网络层、应用层）及各层的作用
- **理解**物联网各层面临的安全风险
- **能够**为后续物联网安全配置核查奠定基础

什么是物联网？ [什么是物联网_哔哩哔哩_bilibili]

官方定义

物联网（Internet of Things，IoT）是通过射频识别（RFID）、红外感应器、全球定位系统、激光扫描器等信息传感设备，按约定的协议，把任何物品与互联网相连接，进行信息交换和通信，以实现智能化识别、定位、跟踪、监控和管理的一种网络。

通俗理解

物联网就是“物物相连的互联网”——给所有的“物”装上传感器，让它们能“说话”、能“交流”、能被“控制”。

物联网的三个核心特征：

01 全面感知

02 可靠传送

03 智能处理

物联网的发展历程

1999年

MIT首次提出概念

概念诞生

2005年

ITU发布相关报告

全球关注

2008年

设备数首超人口

标志性里程碑

2009年

提出“感知中国”战略

中国发展起点

2019年

新增安全扩展要求

安全规范化

物联网的三层架构——总览

物联网体系架构分为三个层次：**感知层、网络层、应用层**。

应用层

——“大脑”

思考和处理

数据汇聚与处理

智能家居　智慧城市　智能工业

网络层

——“神经网络”

传递信息

数据传输

互联网　移动通信　专网

感知层

——“眼睛、耳朵、手脚”

感知和采集

物理世界信息获取

传感器　RFID　摄像头　二维码　GPS　执行器

感知层（一）——定义与功能

感知层是物联网的基础，负责“全面感知”——从物理世界获取信息。

1 信息采集

通过传感器获取温度、湿度、位置、图像等物理量

2 物体标识

通过RFID、二维码等技术唯一标识物体

3 执行控制

通过执行器（继电器、电机等）控制设备动作

设备类型	常见示例	核心功能
传感器	温湿度传感器、光线传感器、压力传感器	将物理量转为电信号
RFID	门禁卡、电子标签及读写器	识别物体身份
二维码/条形码	快递单号、商品条码	低成本身份标识

感知层（二）——安全风险

感知层是物联网安全最脆弱的环节——**设备数量大、部署分散、物理可达性强。**

主要安全威胁	威胁描述	等保要求
物理破坏	设备被破坏、被挪动、被干扰	**8.4.1.1 感知节点设备物理防护**
侧信道攻击	通过功耗、电磁泄漏获取密钥	–
节点俘获	攻击者获取设备控制权	–
伪造节点	假冒合法节点接入网络	**8.4.2.1 接入控制**

网络层——定义与功能

网络层负责“可靠传送”——将感知层采集的数据传输到应用层。

数据传输
将感知层数据通过各种网络协议传输

路由选择
选择最优路径传递数据

网络接入
提供多种接入方式（WiFi、蜂窝、蓝牙等）

常见网络层技术

短距离无线	蜂窝通信	低功耗广域网	有线网络
覆盖小、低功耗	覆盖广、运营商级	低功耗、长距离	稳定、可靠
WiFi、蓝牙、ZigBee、NFC	2G/3G/4G/5G、NB-IoT	LoRa、Sigfox	以太网、RS-485

网络层——安全风险

网络层是物联网攻击最集中的层面——通信协议多样、传输路径复杂。

威胁类型	威胁说明	等保对应要求
中间人攻击	截获、篡改通信数据	8.4.2.2入侵防范
数据窃听	明文传输导致信息泄露	无
拒绝服务攻击	大量设备被控制发动DDoS	无
协议攻击	利用协议漏洞攻击	无
非授权访问	未授权设备接入网络	8.4.2.1接入控制

应用层——定义与功能

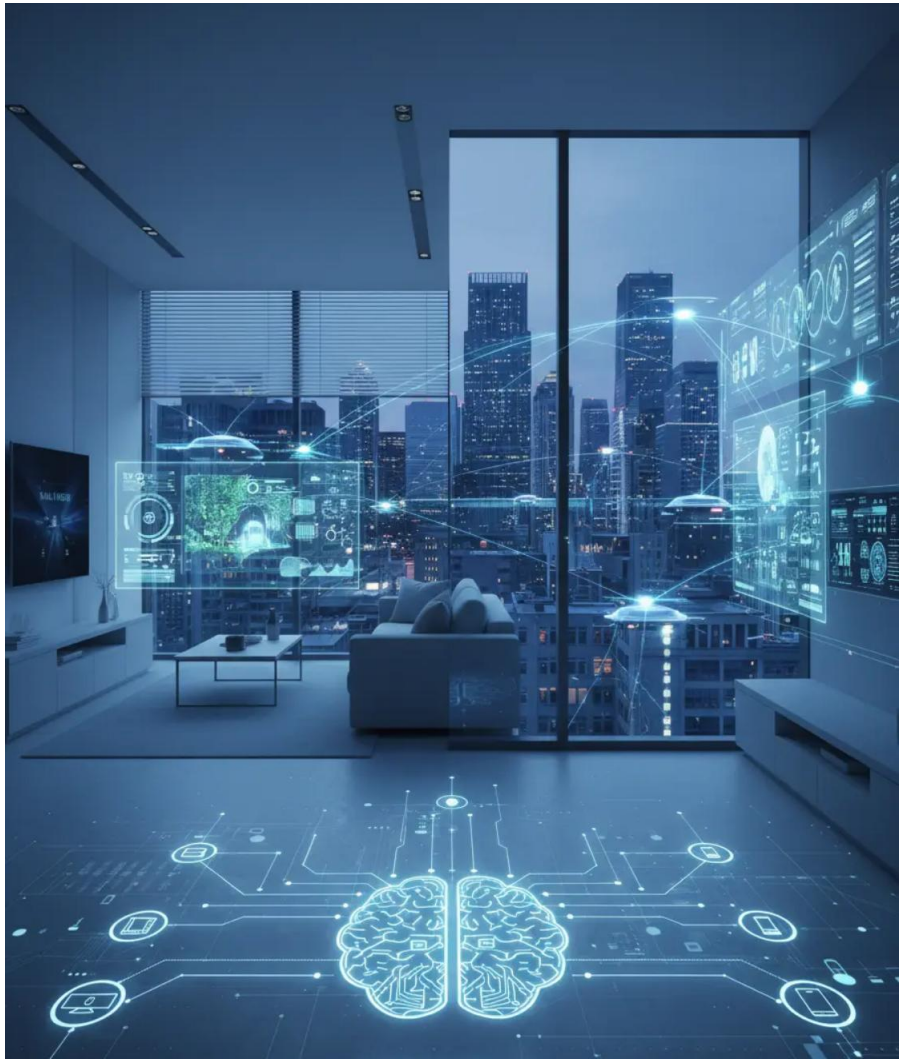
应用层负责**“智能处理”**——对采集到的海量数据进行分析和应用。

核心功能

- **数据处理：**清洗、存储、分析
- **智能决策：**算法判断与决策
- **业务展示：**UI界面展示结果

应用场景

智能家居	智慧城市
工业物联网	农业物联网
医疗物联网	



应用层——安全风险

应用层是物联网数据价值最高、最受攻击者“青睐”的层面。应用层主要安全威胁：

- **数据泄露** 用户隐私、业务数据泄露
- **身份伪造** 冒充合法用户/设备
- **应用漏洞** Web应用、APP安全漏洞
- **云端攻击** 物联网云平台被攻破
- **权限滥用** 越权访问数据或设备

物联网安全挑战——与传统系统的差异

等保测评中，为什么要把物联网单独列为一个扩展要求？因为物联网的安全问题非常特殊。

传统信息系统	对比维度	物联网系统
可控（数十到数百台）	设备数量	**海量（数千到数百万台）**
计算资源充足	设备能力	**资源受限（低功耗、低存储）**
可控机房	部署环境	**野外、无人值守**
3-5年升级	生命周期	**10年以上使用**
可定期打补丁	安全更新	**更新困难**
有线为主	通信方式	**无线为主**
相对集中	攻击面	**极其分散**

物联网安全扩展要求——在等保标准中的位置

GB/T 22239-2019 安全扩展要求 → 物联网安全扩展要求

物联网安全扩展要求的五个维度（第二级/第三级）：

1	**安全物理环境：**	感知节点设备物理防护
2	**安全区域边界：**	接入控制、入侵防范
3	**安全计算环境：**	感知节点设备安全、网关节点设备安全、抗数据重放
4	**安全建设管理：**	感知节点管理
5	**安全运维管理：**	感知节点管理

物联网与等保2.0——重点解读

素材4：物联网各层安全威胁速查表.(

素材5：等保2.0物联网扩展要求快速

物联网安全扩展要求的核心思路：分层防护，逐层加固。（以第三级为例）

防护层	编号	控制点	核心要求
感知层	8. 4. 1. 1	设备物理防护	环境防破坏、反映状态、持久电力
区域边界	8. 4. 2. 1	接入控制	限授权感知节点接入
	8. 4. 2. 2	入侵防范	限制通信目标地址
计算环境	8. 4. 3. 1	感知设备安全	限授权配置，鉴别网关身份
	8. 4. 3. 2	网关设备安全	鉴别合法设备，密钥在线更新
运维管理	8. 4. 4. 1	感知节点管理	定期巡视、保密管理

教师演示——物联网架构图绘制（15分钟）

素材1：教师演示
——物联网三层架构

演示场景

以“智能家居环境监测系统”为例，绘制物联网三层架构图。

系统组成

- **感知层：**温湿度(DHT11)、烟雾、光照传感器、智能插座
- **网络层：**ZigBee/WiFi网关、家庭路由器、互联网
- **应用层：**智能家居云平台、手机APP、Web管理界面

教师演示步骤

1. 画出三层架构框（感知层、网络层、应用层）
2. 感知层填传感器→标“数据采集”
3. 网络层填网关→路由器→标“数据传输”
4. 应用层填云平台→APP→标“处理与展示”

重点标注：每层的安全风险点（红笔标注）

实践任务1——物联网架构辨识（20分钟）


素材2：实践任务
——《物联网架构分


素材3：场景说明
卡（供实践任务使用

任务名称

物联网架构分析与架构图绘制

任务场景

MobLab实验平台“智能园区”页

任务内容

① 识别感知层设备（传感器等）

② 识别网络层技术（WiFi等）

③ 识别应用层系统（云平台等）

④ 绘制三层架构图及安全标注

成果形式

《物联网架构分析记录表》（见素材2）

思政融入——物联网安全关乎国家安全

“感知中国”

2009年温家宝在无锡提出“感知中国”战略；中国是全球物联网产业领先者，安全至关重要

关键基础设施

10万台摄像头被Mirai组成僵尸军团，半个美国的网络瘫痪

数据主权

海量感知数据包含地理、资源、人员等敏感信息；数据安全是国家安全的重要组成部分

物联网让万物互联，也让万物“可被攻击”——安全测评就是给物联网系统装上“防火墙”。

知识点回顾（5分钟）

物联网架构认知

一、物联网基本概念

定义、三个特征

二、三层架构

感知层、网络层、应用层

三、各层安全风险

感知层、网络层、应用层

四、等保物联网扩展要求

物理防护、接入与入侵防范、节点安全

开课之问的答案：攻破半个美国的不是超级计算机，而是10万台“没人管”的摄像头——短板就在感知层。

课后作业

必做	完成《物联网架构分析记录表》（选择一个场景），提交至学习通平台
必做	完成活动7. 3. 1在线测试（选择题+判断题，共15题）
选做	搜索一个物联网安全事件案例，分析其发生在哪一层
预习	预习7. 3. 2“物联网安全配置核查”相关内容

感谢观看

